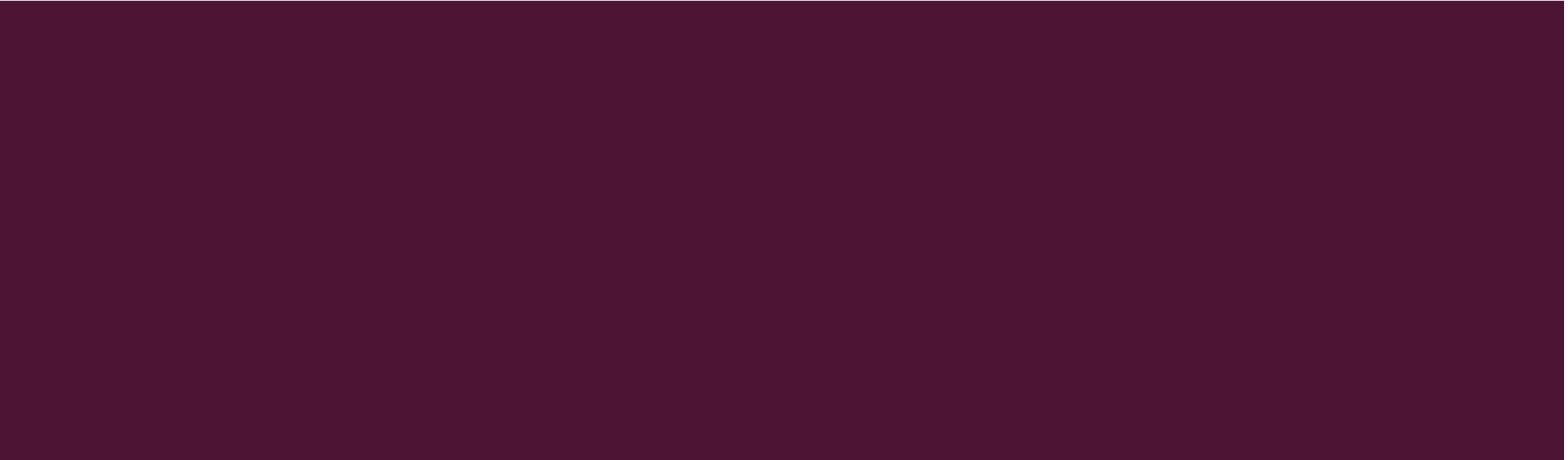




PLANNING FOR SECURITY

INFORMATION SECURITY



OUTLINE

- Introduction
- Governance
- Information Security Policy, Standards, and Practices
- NIST Framework

INTRODUCTION

- Creation of an [information security](#) program begins with:
 1. Creation or review of an organization's [information security policies, standards, and practices](#)
 2. Selection or creation of [information security architecture](#) and a detailed information security blueprint
- Without policy, blueprints, and planning, an organization is unable to meet the [information security needs](#) of various communities of interest

Organizations undertake at least the following plans:

[Strategic planning](#)

[Contingency planning](#)

INFORMATION SECURITY PLANNING AND GOVERNANCE

Governance

- Set of responsibilities and practices exercised by the board and executive management
- Goal to provide strategic direction, ensuring that objectives are achieved
- Determining that risks are managed appropriately and verifying that the enterprise's resources are used responsibly

INFORMATION SECURITY PLANNING AND GOVERNANCE OUTCOMES

- Information Security Governance outcomes
 - Strategic
 - Aligned Risk management
 - Resource management
 - Performance measure

INFORMATION SECURITY POLICY, STANDARDS, AND PRACTICES

- **Policy:** course of action used by organization to convey instructions from management to those who perform duties Policies are organizational laws
- **Standards:** more detailed statements of what must be done to comply with policy
- **Practices, procedures, and guidelines** effectively explain how to comply with policy
- For a policy to be effective, it must be properly **disseminated, read, understood, and agreed** to by all members of organization and uniformly enforced

Policies are sanctioned by senior management

Policies

DRIVE

Standards are built on sound policy and carry the weight of policy

Standards

DRIVE

Practices, procedures, and guidelines include detailed steps required to meet the requirements of standards

Practices

Procedures

Guidelines



OUTLINE

- NIST Cybersecurity Framework
- Framework Core Structure
- Functions
- Categories
- Tiers

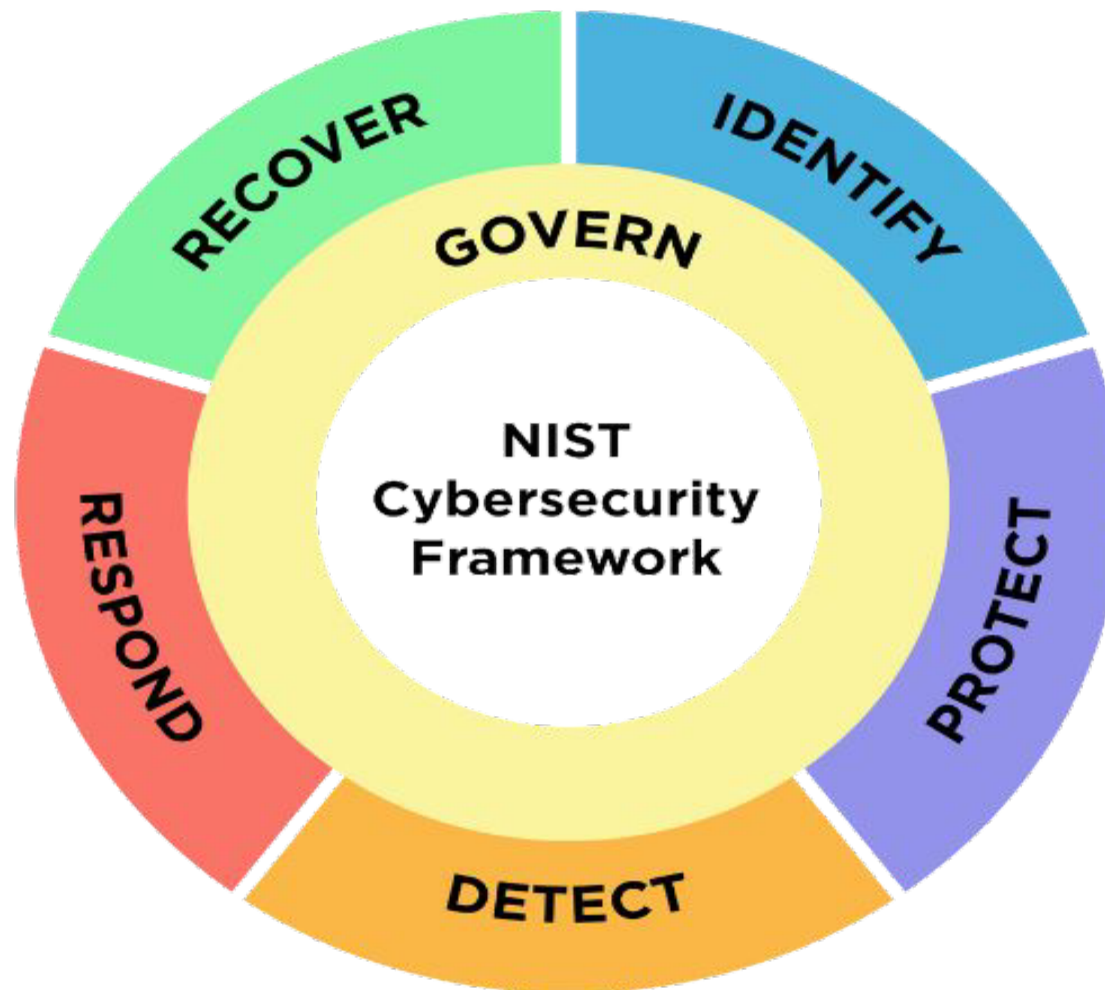
WHAT IS THE NIST CYBERSECURITY FRAMEWORK?

- The National Institute of Standards and Technology (NIST) is a non-regulatory agency that promotes innovation by advancing measurement science, standards, and technology.
- The NIST Cybersecurity Framework (NIST CSF) consists of standards, guidelines, and best practices that help organizations improve their management of cybersecurity risk.
- The NIST CSF is designed to be flexible enough to integrate with the existing security processes within any organization, in any industry.
- It provides an excellent starting point for implementing information security and cybersecurity risk management in virtually any private sector organization in the United States.

NIST CYBERSECURITY FRAMEWORK CORE STRUCTURE

- NIST Cybersecurity Framework includes *functions, categories, subcategories, and informative references*.
- Functions give a general overview of security protocols of best practices.
- Functions are not intended to be procedural steps but are to be performed **“concurrently and continuously to form an operational culture that addresses the dynamic cybersecurity risk.”**
- Categories and subcategories provide more concrete action plans for specific departments or processes within an organization.

NIST CYBERSECURITY FRAMEWORK CORE STRUCTURE



NIST CYBERSECURITY FRAMEWORK CORE STRUCTURE

Capability

Description

Identify

What processes and assets need protection?

Protect

Implement appropriate safeguards to ensure protection of the enterprise's assets

Detect

Implement appropriate mechanisms to identify the occurrence of cybersecurity incidents

Respond

Develop techniques to contain the impacts of cybersecurity events

Recover

Implement the appropriate processes to restore capabilities and services impaired due to cybersecurity events

NIST FUNCTIONS AND CATEGORIES

- **Identify:** To protect against cyberattacks, the cybersecurity team needs a thorough understanding of what are the most important assets and resources of the organization.
- The identify function includes such categories as asset management, business environment, governance, risk assessment and risk management strategy.

NIST FUNCTIONS AND CATEGORIES

Protect:

- The protect function covers much of the technical and physical security controls for developing and implementing appropriate safeguards and protecting critical infrastructure.
- These categories are identity management and access control, awareness and training, data security, information protection processes and procedures, maintenance, and protective technology.

NIST FUNCTIONS AND CATEGORIES

Detect:

- The detect function implements measures that alert an organization to cyberattacks.
- Detect categories include anomalies and events, security continuous monitoring, and detection processes.

NIST FUNCTIONS AND CATEGORIES

Respond:

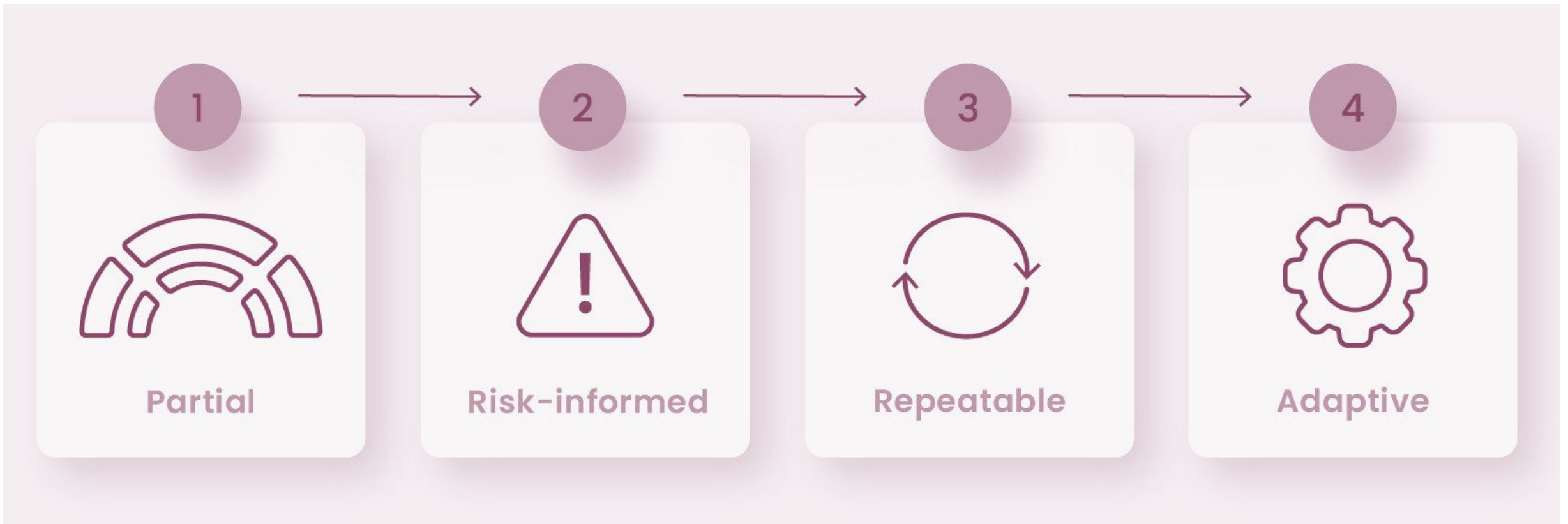
- The respond function categories ensure the appropriate response to cyberattacks and other cybersecurity events.
- Specific categories include response planning, communications, analysis, mitigation, and improvements.

NIST FUNCTIONS AND CATEGORIES

Recover:

- Recovery activities implement plans for cyber resilience and ensure business continuity in the event of a cyberattack, security breach, or other cybersecurity event.
- The recovery functions are recovery planning improvements and communications.

NIST FRAMEWORK IMPLEMENTATION TIERS



NIST FRAMEWORK IMPLEMENTATION TIERS

To help private sector organizations measure their progress towards implementing the NIST Cybersecurity Framework, the framework identifies four implementation tiers:

Tier I – Partial:

- The organization is familiar with the NIST CSF and may have implemented some aspects of control in some areas of the infrastructure.
- Implementation of cybersecurity activities and protocols has been reactive vs. planned.
- The organization has limited awareness of cybersecurity risks and lacks the processes and resources to enable information security.

NIST FRAMEWORK IMPLEMENTATION TIERS

Tier 2 – Risk Informed:

- Tier 2 businesses recognize that cybersecurity risks exist and that they need to be managed.
 - However, they lack standard procedures and company-wide awareness of threats.
- The organization is more aware of cybersecurity risks and shares information on an informal basis.
- It lacks a planned, repeatable, and proactive organization-wide cybersecurity risk management process.

NIST FRAMEWORK IMPLEMENTATION TIERS

Tier 3 – Repeatable:

- Tier 3 organizations have developed and implemented procedures for managing cybersecurity risks. This includes incident response plans, security awareness training, and regular security assessments.
- The organization and its senior executives are aware of cybersecurity risks.
- They have implemented a repeatable, organization-wide cybersecurity risk management plan.
- The cybersecurity team has created an action plan to monitor and respond effectively to cyberattacks.

NIST FRAMEWORK IMPLEMENTATION TIERS

■ Tier 4 – Adaptive:

- Continuously improving the organization's approach to managing cybersecurity risks. This includes making changes in response to incidents, new threats, and changing business needs.
- The organization is now cyber resilient and uses lessons learned and predictive indicators to prevent cyberattacks.
- The cybersecurity team continuously improves and advances the organization's cybersecurity technologies and practices and adapts to changes in threats quickly and efficiently.
- There is an organization-wide approach to information security risk management with risk informed decision-making, policies, procedures, and processes.
- Adaptive organizations incorporate cybersecurity risk management into budget decisions and organizational culture.



Any Questions?